

Durante l'esame, ci sarà una domanda legata ad uno dei "Mandatory Readings": verrà richiesto di riassumere ciò (scrivere Punti importanti riguardanti Cybersecurity) e di scrivere dei commenti critici e tecnici (ad esempio: che cosa fare per mitigare il problema?) (alcune volte ci sono delle domande specifiche tecniche su Mandatory Readings)

La parte importante è: capire qual'è il problema ed i differenti punti importanti della lettura

Situation: IoT in which we have devices that are vulnerable, possibly compromised and very likely, when compromised, will go on compromised for a lot of time

Old but still important these days

BRUCE SCHNEIER
CySec Big Name

OPINION JAN 6, 2014 6:38 AM

The Internet of Things Is Wildly Insecure – And Often Unpatchable

Insecurity of embedded system is linked with IoT insecurity

We're at a crisis point now with embedded systems, which includes the Internet of Things. These computers are riddled with insecurities -- and there's no good way to patch them. It's not unlike what happened in the mid-1990s with PCs, only now the devices are connected to the Internet and the industries producing them are even less capable of fixing the problem than the PC and software industries were.

pieni di vulnerabilità

modo efficace

La situazione non è molto diversa da

standard computer vs embedded system

- 1) Hardware (embedded less powerful)
- 2) UI (for a computer there is a monitor and m&k, for an embedded this is missing)
- 3) Management and Installation (for a standard computer, there is someone expert that manage and setup it, for an embedded easy setup by anyone and no management)



ILLUSTRATION: ALENGO/GETTY IMAGES

 SAVE

An embedded system is a specialized, dedicated computing system designed to perform specific tasks within a larger mechanical or electrical device. Unlike PCs, they are characterized by limited resources and often operate under real-time constraints.

If you buy something using links in our stories, we may earn a commission. This helps support our journalism. [Learn more.](#) Please also consider [subscribing to WIRED](#)

WE'RE AT A crisis point now with regard to the security of embedded systems, where computing is embedded into the hardware itself -- as with the Internet of Things. These embedded computers are riddled with vulnerabilities, and there's no good way to patch them.

It's not unlike what happened in the mid-1990s, when the insecurity of personal computers was reaching crisis levels. Software and operating systems were riddled with security vulnerabilities, and there was no good way to patch them. Companies were trying to keep vulnerabilities secret, and not releasing security updates quickly. And when updates were released, it was hard -- if not impossible

**DACIA SANDERO STEPWAY
ECO-G 100**

DA 89€*/ RATA MESE - TAN 3,99% - TAEG 5,63%
ANTICIPO 4.830 € - 36 RATE - RATA FINALE 10.647 € O SEI LIBERO DI RESTITUIRLA.

OFFERTA VALIDA SOLO A GENNAIO SU UN NUMERO LIMITATO DI VETTURE IN PRONTA CONSEGNA FINO AD ESAURIMENTO SCORTE. INFO E CONDIZIONI PRESSO LA RETE ADERENTE.

NOTA: GAMMA SANDERO STEPWAY. Dimensioni di CO₂ da 114 a 148 g/km. Velocità (ciclo misto) da 5,5 a 7,4 (100 km). Emissioni e consumi omologati secondo la normativa comunitaria vigente. Immagine non rappresentativa del prodotto. Offerta valida presso la Rete aderente fino al 30/01/2023.

*Esempio di finanziamento con valore tuttora garantito offerto a Sandero Stepway Expression Eco-G 100 e 14.900 (IVA inclusa, IPT e contributo PRU esclusi), anticipo € 4.830, importo totale del credito € 12.420,00 (che include finanziamento veicolo € 12.070 e spese istruttoria pratica € 750) - imposta di bollo € 31,05 (anticipata nella prima rata), TAN 3,99%, TAEG 5,63%, Valore Futuro Garantito € 18.447 (Data Maturità, per un chilometraggio totale massimo di 10.000 km, in caso di restituzione del veicolo, si applica riduzione di € 12.070,00, importo totale dovuto dal consumatore € 13.326,00 da 36 rate da € 664,00 oltre la rata finale TAN 3,99% (Importo Finanziato, TAEG 5,63%, tasso di incasso mensile € 3, tasso per la restituzione anticipata del veicolo € 2,50). Come alternativa, poterla restituire alla scadenza di bollo pari a € 2. Salvo approvazione Mediocredito Centrale. Documentazione personalizzata del Mediocredito Centrale presso i punti vendita della Rete (dalla convenzionata Mediocredito Finanziaria Servizi e sul sito mediocredito.it/risparmio). Messaggio pubblicitario con finalità promozionale. Offerta della Rete Banca che aderisce all'indicatore valore fino al 30/01/2023.

Our biggest stories, handpicked for you each day.

By signing up, you agree to our [user agreement](#) (including [class action waiver and arbitration provisions](#)), and acknowledge our [privacy policy](#).

But this time the problem is much worse, because the world is different: All of these devices are connected to the Internet. The computers in our routers and modems are much more powerful than the PCs of the mid-1990s, and the Internet of Things will put computers into all sorts of consumer devices. The industries producing these devices are even less capable of fixing the problem than the PC and software industries were.

If we don't solve this soon, we're in for a security disaster as hackers figure out that it's easier to hack routers than computers. At a recent Def Con, a researcher looked at thirty home routers and broke into half of them -- including some of the most popular and common brands.

Bruce Schneier

Bruce Schneier is the Chief Technology Officer of Co3 Systems. His latest book is *Carry On: Sound Advice from Schneier on Security*.

To understand the problem, you need to understand the embedded systems market.



For these systems, Time to market is very important to place the product on the market (margin are better if you are the only one or in a few)

Typically, these systems are powered by specialized computer chips made by companies such as Broadcom, Qualcomm, and Marvell. These chips are cheap, and the profit margins slim. Aside from price, the way the manufacturers differentiate themselves from each other is by features and bandwidth. They typically put a version of the Linux operating system onto the chips, as well as a bunch of other open-source and proprietary components and drivers. They do as little engineering as possible before shipping, and there's little incentive to update their "board support package" until absolutely necessary.

margin di profitto sono ridotti

A BSP is the essential software layer that allows an OS to run on a specific embedded hardware board. It acts as a bridge, containing drivers, configuration files, and bootloader code that allow the OS to interact with the processor and peripherals.

The system manufacturers -- usually original device manufacturers (ODMs) who often don't get their brand name on the finished product -- choose a chip based on price and features, and then build a router, server, or whatever. They don't do a lot of engineering, either. The brand-name company on the box may add a user interface and maybe some new features, make sure everything works, and they're done, too. (the only one who cares a little about security, is the brand-name company)

The problem with this process is that no one entity has any incentive, expertise, or even ability to patch the software once it's shipped. The chip manufacturer is busy shipping the next version of the chip, and the ODM is busy upgrading its product to work with this next chip. Maintaining the older chips and products just isn't a priority.

(timing the market)

(timing the market)

And the software is old, even when the device is new. For example, one survey of common home routers found that the software components were four to five years older than the device. The minimum age of the Linux operating system was four years. The minimum age of the Samba file system software: six years. ~~They may have had all the security patches applied, but most likely not.~~ Potrebbero avere tutte le patch di sicurezza applicate, ma molto probabilmente non è così. No one has that job. Some of the components are so old that they're no longer being patched. This patching is especially important because security vulnerabilities are found "more easily" as systems age.

To make matters worse, it's often impossible to patch the software or upgrade the components to the latest version. Often, the complete source code isn't available. Yes, they'll have the source code to Linux and any other open-source components. But many of the device drivers and other components are just "binary blobs" -- no source code at all. That's the most ~~pernicious~~ dangerous part of the problem: No one can possibly patch code that's just binary.

Even when a patch is possible, it's rarely applied. Users usually have to manually download and install relevant patches. But since users never get alerted about security updates, and don't have the expertise to manually ~~administer~~ administrare these devices, it doesn't happen. Sometimes the ISPs have the ability to remotely patch routers and modems, but this is also rare.

The result is hundreds of millions of devices that have been sitting on the Internet, unpatched and insecure, for the last five to ten years.

Hackers are starting to notice. Malware DNS Changer attacks home routers as well as computers. In Brazil, 4.5 million DSL routers were compromised for purposes of financial fraud. Last month, Symantec reported on a Linux worm that targets routers, cameras, and other embedded devices.

This is only the beginning. All it will take is some easy-to-use hacker tools for the script kiddies to get into the game.

And the Internet of Things will only make this problem worse, as the Internet -- as well as our homes and bodies -- becomes flooded with new embedded devices that will be equally poorly maintained and unpatchable. But routers and modems pose a particular problem, because they're: (1) between users and the Internet, so turning them off is increasingly not an option; (2) more powerful and more

general in function than other embedded devices; (3) the one 24/7 computing device in the house, and are a natural place for lots of new features.

We were here before with personal computers, and we fixed the problem. But disclosing vulnerabilities in an effort to force vendors to fix the problem won't work the same way as with embedded systems. The last time, the problem was computers, ones mostly not connected to the Internet, and slow-spreading viruses. The scale is different today: more devices, more vulnerability, viruses spreading faster on the Internet, and less technical expertise on both the vendor and the user sides. Plus vulnerabilities that are impossible to patch.

Combine full function with lack of updates, add in a pernicious market dynamic that has inhibited updates and prevented anyone else from updating, and we have an incipient disaster in front of us. It's just a matter of when.

We simply have to fix this.¹ We have to put pressure on embedded system vendors to design their systems better.² We need open-source driver software -- no more binary blobs! -- so third-party vendors and ISPs can provide security tools and software updates for as long as the device is in use.³ We need automatic update mechanisms to ensure they get installed.

⁴ The economic incentives point to large ISPs as the driver for change. Whether they're to blame or not, the ISPs are the ones who get the service calls for crashes. They often have to send users new hardware because it's the only way to update a router or modem, and that can easily cost a year's worth of profit from that customer. This problem is only going to get worse, and more expensive. Paying the cost up front for better embedded systems is much cheaper than paying the costs of the resultant security disasters.

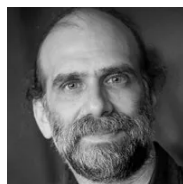
Editor: Sonal Chokshi @smc90

Schneier paragona spesso l'ISP a una società di servizi pubblici (come l'acqua). Se la tua casa ha una perdita che danneggia il quartiere, la compagnia idrica chiude l'acqua. Allo stesso modo, se un dispositivo dell'utente fa parte di una Botnet e genera traffico anomalo, l'ISP è l'unico soggetto tecnico in grado di isolare il problema per proteggere il resto di Internet.

There are three types of liability:

- 1) Producer liability
- 2) ISP liability
- 3) User liability

For B.Schneier, The one that should do something is ISP (if the customer consume a lot of bandwidth, stop the customer's connection to Internet if they have vulnerable devices, until they fixed them)



For the Prof. the solution should be in part Technological and in part about Regulations (example: CRA)

Bruce Schneier is a technologist, cryptographer, and security specialist, and the author of *A Hacker's Mind*.

Theoretically, we can solve, in the same way that has be done in 90s, using Automatic Updates. Practically, we can't because of two main aspects: (1)Technical and (2)Liability.

1) Even if the devices are the same, the conditions in which the device is installed and used are different (same for configuration) (example: fixing a vulnerability and pushing an update with the fix for a device. While the update may work for most, it can "brick" or disable others, rendering them operationally dead and creating a self-inflicted denial-of-service.)

2) If an automatic update starts and triggers a failure during peak business hours, the resulting downtime can be devastating. (example: security camera or automatic doors open with digital keys: it compromises physical security and halts business operations.)